

Why Traditional TPRM Fails for AI

Redesigning TPRM for the Age of AI

Index

01	Cover	Cover
02	The Problem: Legacy TPRM Wasn't Built for This	2
03	Legacy vs. AI-Ready TPRM: A Framework Comparison	4
04	AI Vendor Risk Taxonomy	5
T1	Template: AI Vendor Risk Scoring Rubric	6
05	The Solution: Building an AI-Ready TPRM Program	7
T2	Template: AI Vendor Governance RACI	10
06	AI Vendor Assessment: Key Questions	11
T3	Template: AI TPRM Evidence Checklist	13
07	Implementation Roadmap	14
08	Key Takeaways	16

The Problem: Legacy TPRM Wasn't Built for This

Traditional Third-Party Risk Management was designed for static, deterministic technology – SaaS platforms, outsourced services, and data processors with predictable behavior. AI vendors introduce a fundamentally different risk profile that legacy frameworks cannot capture.

What Makes AI Vendors Different?

Dimension	Traditional Vendor	AI Vendor
Behavior	Deterministic, predictable outputs	Probabilistic, outputs evolve over time
Data Usage	Processes/stores your data	May train on, retain, or leak your data
Performance	Stable once deployed	Model drift degrades accuracy silently
Transparency	Clear logic, auditable code	Black-box models, limited explainability
Supply Chain	Known sub-processors	Foundation models, datasets, fine-tuning layers
Regulatory	Mature compliance (SOC 2, ISO 27001)	Emerging & fragmented (EU AI Act, NIST AI RMF)

Key Insight: A vendor questionnaire asking "Do you encrypt data at rest?" tells you nothing about whether an AI model memorizes and regurgitates your sensitive data in responses to other customers.

5 Core Failure Points of Traditional TPRM for AI

- **Static assessments** – Annual questionnaires can't track models that update weekly
- **No model-layer visibility** – Risk sits in training data, weights, and inference logic – not just infrastructure
- **Missing AI-specific controls** – No questions on hallucination rates, bias testing, or data provenance
- **Inadequate contractual coverage** – SLAs lack terms for model accuracy, retraining notification, or IP indemnity
- **Shadow AI blind spots** – Employees adopt AI tools faster than procurement can assess them

Failure Signals & TPRM Response

Signal	What It Indicates	TPRM Response
Vendor cannot explain data retention, logging, or model training use	Data rights and leakage risk are unclear	Require AI data-use attestation and contract controls
No process for notifying customers about model or sub-processor changes	Risk profile can shift without review	Add model-change notification and reassessment triggers
AI output influences regulated or customer-facing decisions	Business impact exceeds standard SaaS controls	Escalate tiering and require human oversight evidence

Legacy vs. AI-Ready TPRM: A Framework Comparison

The shift from traditional to AI-aware TPRM isn't incremental – it requires new dimensions of assessment entirely.

Assessment Area	Legacy TPRM Approach	AI-Ready TPRM Approach
Vendor Inventory	IT-managed vendor register	AI-specific registry including shadow AI discovery
Risk Tiering	Based on data access & spend	Adds model autonomy, decision impact & data ingestion scope
Due Diligence	SOC 2 + security questionnaire	+ Model card review, bias audit, explainability assessment
Ongoing Monitoring	Annual reassessment	Continuous monitoring of model performance & drift
Contractual Controls	Standard DPA + SLA	+ AI-specific clauses: training data rights, model versioning, output liability
Incident Response	Breach notification (72h)	+ Hallucination/bias incident protocols, model rollback triggers
Exit Strategy	Data return/deletion	+ Model decommissioning, learned-data purge verification

The Gap: Most organizations still use the left column. The right column represents where mature programs need to be within 12-18 months to meet regulatory expectations.

AI Vendor Risk Taxonomy

To build an AI-ready TPRM program, you need to assess risk across dimensions that don't exist in traditional frameworks.

Model Risk

Hallucinations, bias, drift, accuracy degradation, adversarial vulnerability, lack of explainability

Data Risk

Training data provenance, data leakage in outputs, cross-tenant contamination, PII in embeddings

Compliance Risk

EU AI Act classification gaps, sector-specific requirements, cross-border data flows for model training

Supply Chain Risk

Foundation model dependencies, dataset sourcing, fine-tuning pipelines, plugin/tool ecosystems

Contractual Risk

IP ownership of outputs, liability for AI-generated decisions, retraining notification gaps

Operational Risk

Shadow AI proliferation, over-reliance on single model providers, vendor lock-in on proprietary models

Risk Tiering Model for AI Vendors

Tier	Criteria	Assessment Depth	Review Cadence
Critical	Autonomous decisions, PII/sensitive data, customer-facing	Full AI due diligence + on-site	Quarterly
High	Augments human decisions, accesses internal data	AI questionnaire + model card review	Semi-annual
Medium	Internal productivity tools, no sensitive data	Streamlined AI checklist	Annual
Low	Embedded AI features, minimal data exposure	Vendor self-attestation	Annual (light)

Template: AI Vendor Risk Scoring Rubric

Use this scoring rubric to translate AI vendor characteristics into a consistent risk tier. Score each dimension from 1 to 4, then use the total to determine the assessment path.

Dimension	Score	Scoring Guidance
Data Sensitivity	1-4	1 = public or non-sensitive data; 2 = internal business data; 3 = confidential, employee, or customer data; 4 = regulated, sensitive, or high-volume PII/PHI/financial data.
AI Autonomy	1-4	1 = passive summarization or search; 2 = recommendation support; 3 = workflow decisions with human review; 4 = autonomous action, approval, or customer-impacting decisions.
Business Impact	1-4	1 = low productivity use; 2 = internal operational support; 3 = material business process; 4 = customer-facing, regulated, financial, safety, or employment impact.
Model Dependency	1-4	1 = no external model dependency; 2 = embedded model with limited exposure; 3 = foundation model or fine-tuned model dependency; 4 = multi-model, agentic, plugin, or tool ecosystem dependency.
Transparency	1-4	1 = model card, logs, testing, and clear audit support; 2 = partial documentation; 3 = limited explainability or testing evidence; 4 = black-box behavior with weak auditability.

Total Score	Risk Tier	Required Action
17-20	Critical	Full AI due diligence, legal/privacy review, model evidence review, executive risk acceptance, quarterly monitoring.
13-16	High	AI questionnaire, model card review, contract uplift, monitoring plan, semi-annual reassessment.
8-12	Medium	Streamlined AI checklist, basic evidence review, annual reassessment.
5-7	Low	Vendor self-attestation and lightweight annual review.

Rule of thumb: Any vendor with regulated data, autonomous action, or customer-facing AI should be escalated at least one tier even if the total score appears moderate.

The Solution: Building an AI-Ready TPRM Program

Redesigning TPRM for AI doesn't mean starting over – it means layering AI-specific capabilities onto your existing program structure.

Transformation Lifecycle



Phase 1: Discover & Classify

- Conduct an **AI vendor census** – survey all departments for tools using ML/AI capabilities
- Identify **shadow AI** through network traffic analysis, expense reports, and SSO logs
- Classify each vendor using the AI risk tiering model (Critical to Low)
- Map **AI supply chains** – which foundation model does each vendor rely on?

Phase 2: AI-Enhanced Assessment

- Supplement existing questionnaires with an **AI-specific module** (15–25 targeted questions)
- Request **model cards** or AI transparency documentation from vendors
- Evaluate vendor's **AI governance maturity** (responsible AI policies, bias testing, red-teaming)
- Assess **data handling for AI** – training data rights, opt-out mechanisms, data retention in models

Phase 3: Contractual Uplift

- Add **AI-specific clauses** to vendor agreements: model versioning, retraining notifications, output liability
- Define **AI performance SLAs**: accuracy thresholds, hallucination rate caps, response time for bias reports
- Establish **right to audit** model behavior (not just infrastructure)
- Include **IP and indemnity provisions** for AI-generated outputs

Phase 4: Continuous Monitoring & Response

Annual reassessments are insufficient for AI vendors. Models change, data shifts, and new vulnerabilities emerge continuously.

Continuous Monitoring Framework

Signal	What to Monitor	Frequency	Trigger Action
Model Updates	Version changes, retraining events	Real-time (via vendor notification)	Re-assess impacted controls
Performance Drift	Accuracy, latency, output quality	Weekly/Monthly	Escalate if below SLA threshold
Regulatory Changes	New AI regulations, enforcement actions	Monthly	Gap analysis & vendor outreach
Incident Reports	Vendor breaches, bias incidents, outages	Real-time	Invoke AI incident response plan
Vendor Ecosystem	M&A, funding changes, key personnel	Quarterly	Concentration risk review

AI Incident Response Additions

Beyond data breaches: Your incident response plan needs new playbooks for AI-specific scenarios:

- **Hallucination incident** – AI generates false information affecting customers or decisions
- **Bias detection** – Model produces discriminatory outputs across protected classes
- **Data leakage via model** – Sensitive information surfaces in AI responses
- **Model compromise** – Adversarial manipulation or prompt injection at scale
- **Regulatory non-compliance** – Vendor's AI classified as high-risk under new regulation

Governance Operating Model



Cross-functional oversight body - meets monthly, escalation authority to CISO/CRO

Council Operating Cadence

Area	Cadence	Output
Critical and High-tier AI vendor review	Monthly	Updated risk register, KRIs, remediation owners
Model updates, incidents, and regulatory watch	Monthly	Escalation summary for CISO/CRO review
Accepted risk and exception decisions	As needed	Decision log with owner, expiry date, and conditions
New AI features, agents, or foundation dependencies	Trigger-based	Re-tiering decision and assessment scope update

Template: AI Vendor Governance RACI

Use this RACI to assign ownership across the AI vendor lifecycle. It prevents gaps between TPRM, AI/ML SMEs, Legal, Privacy, Security, and business owners.

Activity	Business Owner	TPRM	AI/ML SME	Security	Privacy	Legal
AI vendor inventory and use-case capture	R	A	C	C	C	I
Risk tiering and assessment scope	C	A/R	C	C	C	I
Model card and AI evidence review	I	C	A/R	C	C	I
Data-use, retention, and opt-out review	C	C	C	I	A/R	C
Contract clauses and liability terms	C	C	I	I	C	A/R
Continuous monitoring and KRI review	C	A/R	C	R	C	I
AI incident response and escalation	R	C	C	A/R	C	C
Residual risk acceptance	A/R	C	C	C	C	C

RACI key: R = Responsible, A = Accountable, C = Consulted, I = Informed. One accountable owner should be named for every AI vendor risk decision.

AI Vendor Assessment: Key Questions

Below is a curated set of high-impact questions to add to your TPRM questionnaire for AI vendors – organized by risk domain.

Model Governance

#	Question	Why It Matters
1	Do you publish model cards or AI transparency documentation?	Demonstrates commitment to explainability
2	How frequently are models retrained, and how are customers notified?	Prevents silent behavior changes
3	What bias and fairness testing do you perform before deployment?	Regulatory & reputational protection
4	Do you conduct adversarial/red-team testing on your models?	Security posture of the AI layer

Data Handling

#	Question	Why It Matters
5	Is customer data used to train or fine-tune models? Can we opt out?	Core data rights concern
6	How do you prevent cross-tenant data leakage in shared models?	Multi-tenancy risk in AI
7	What is the provenance of your training data? Any known legal disputes?	IP & compliance exposure
8	Can learned information about our org be fully purged upon contract end?	Exit strategy assurance

Operational & Compliance

#	Question	Why It Matters
9	What is the measured hallucination/error rate for your model?	Performance accountability
10	How do you classify your AI system under the EU AI Act?	Regulatory alignment
11	What is your human oversight model for high-risk decisions?	Autonomous decision guardrails
12	Do you carry AI-specific liability insurance?	Financial risk transfer

Security & Abuse Resistance

#	Question	Why It Matters
13	How do you test for prompt injection, jailbreak attempts, and unsafe tool use?	Abuse prevention
14	Can agents, plugins, or tools take action without human approval?	Autonomy risk
15	What logs are available for prompts, outputs, tool calls, and model actions?	Auditability

Template: AI TPRM Evidence Checklist

Use this checklist to standardize what vendors must provide during AI due diligence and ongoing monitoring. Evidence should be mapped to the vendor's tier and use case.

Evidence Area	Request From Vendor	Review Focus
Model Transparency	Model card, system description, model owner, versioning process, known limitations	Explainability, change control, intended use, model boundaries
Data Handling	Training/fine-tuning data policy, customer data use, opt-out process, retention policy	Data rights, leakage risk, cross-tenant controls, deletion assurance
Testing & Safety	Bias/fairness testing, hallucination/error metrics, red-team summary, prompt-injection testing	Model reliability, abuse resistance, regulatory exposure
Security Controls	SOC 2/ISO evidence, access controls, logging, incident history, vulnerability process	Baseline security plus AI-layer attack paths
Contracts & Liability	AI clauses, output liability, IP terms, retraining notice, audit rights, insurance	Enforceable accountability and financial risk transfer
Monitoring	Model update notices, SLA metrics, incident alerts, regulatory change process	Ongoing assurance after onboarding

Evidence standard: Do not accept policy statements alone for Critical or High vendors. Ask for artifacts, logs, test summaries, or contractual language that can be independently reviewed.

Implementation Roadmap

A phased approach to maturing your TPRM program for AI – designed to show value quickly while building toward comprehensive coverage.

90-Day Quick Wins (Foundation)

Goal: Visibility & basic governance in place

- Complete AI vendor inventory (including shadow AI discovery)
- Apply AI risk tiering to top 20 vendors
- Draft AI-specific questionnaire module (12–15 priority questions)
- Brief executive leadership on AI TPRM gap assessment

6-Month Milestones (Operationalize)

- Deploy AI questionnaire module to all Critical & High-tier vendors
- Establish AI Vendor Risk Council with cross-functional membership
- Update contract templates with AI-specific clauses
- Build AI incident response playbooks
- Integrate continuous monitoring signals for top 10 AI vendors

12-Month Target State (Mature)

- Full AI TPRM lifecycle operational across all tiers
- Automated model performance monitoring dashboards
- AI vendor risk reporting integrated into enterprise risk register
- Annual AI-specific tabletop exercise completed
- Regulatory mapping (EU AI Act, NIST AI RMF) embedded in assessments

Maturity Indicators

Level	Description	Characteristics
1 - Initial	Ad hoc	No AI-specific TPRM; standard questionnaires applied to AI vendors
2 - Developing	Aware	AI inventory exists; basic questions added; manual monitoring
3 - Defined	Structured	AI risk taxonomy applied; tiered assessments; updated contracts
4 - Managed	Measured	Continuous monitoring; KRIs tracked; council operational
5 - Optimized	Adaptive	Automated, predictive; regulatory-aligned; industry-leading

Maturity Evidence & Metrics

Metric	Evidence	Why It Matters
Inventory coverage	AI vendor register with owner, use case, model dependency, and risk tier	Shows visibility into AI use
Assessment completion	AI questionnaires, model-card reviews, and contract clause status	Proves controls are operational
Risk burn-down	Open issues, accepted risks, KRIs, remediation progress, and SLA exceptions	Creates board-ready reporting

Key Takeaways

The Bottom Line: AI doesn't break your TPRM program – it exposes the gaps that were always there, then adds entirely new risk dimensions on top. The solution isn't to replace your program, but to evolve it.

Remember These Principles

- **AI risk is dynamic** – static, annual assessments are fundamentally insufficient for technology that changes weekly
- **The model IS the risk** – you can't assess AI vendor risk by looking only at infrastructure and certifications
- **Contracts must evolve** – standard DPAs and SLAs don't cover output liability, training data rights, or model versioning
- **Cross-functional ownership** – TPRM teams need AI/ML expertise embedded in their processes
- **Start with visibility** – you can't manage risk you can't see; shadow AI discovery is step one

Standards & Frameworks to Leverage

Framework	Relevance to AI TPRM
NIST AI RMF	Risk identification & governance structure for AI systems
ISO 42001	AI management system requirements – use as vendor maturity benchmark
EU AI Act	Risk classification, mandatory requirements for high-risk AI
ISO 27001 + 27701	Foundation controls – necessary but not sufficient for AI
SSPA / CAIQ	Existing questionnaire frameworks to extend with AI modules

The winners in AI governance will be the teams that can explain, monitor, and control third-party AI before it becomes enterprise risk.
AI governance maturity is becoming a market differentiator.